PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Administration sécurisée Active Directory

03-490 ANSSI - Administration sécurisée des SI reposant sur Active Directory — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le modèle en trois Tiers découpe le système d'information en niveaux de confiance allant du Tier zéro (cœur de confiance) au Tier deux (postes de travail).
2. Un chemin de contrôle est une succession de permissions ou de dépendances techniques permettant de progresser d'une ressource de moindre confiance vers une ressource de plus haute confiance.
3. L'enterprise access model est l'évolution du modèle en trois Tiers publiée par Microsoft fin 2020.

Modèle de gestion des accès privilégiés

Notion	À retenir
Les trois Tiers	Modèle historique ou `enterprise access model` recommandé ; protection du **Tier zéro** prioritaire, **Tier un** porte les valeurs métiers essentielles ; protection proportionnée à la sensibilité.
Enjeux et périmètre	Empêcher la progression d'une zone de moindre confiance vers une zone supérieure via chemins d'attaque **AD**, cloisonnement **réseau**, **système** et **physique** ; périmètre : **forêt AD**.
Méthodologie itérative	Processus itératif : définir périmètre, identifier valeurs **Tier un**, analyser chemins d'attaque vers **Tier 0** et **Tier un**, catégoriser, cloisonner, durcir, déléguer et journaliser.

Durcissement du Tier Zéro

Notion	À retenir
Versions et configuration	Augmenter les **niveaux fonctionnels** (domaines/forêts), utiliser **Windows récent**, maintenir la sécurité et privilégier **Windows Server Core**.
Objets et approbations	Analyser les **chemins de contrôle**, durcir les **approbations sortantes** (authentification sélective), interdire la **délégation Kerberos** entrante et utiliser des **outils d'analyse**.

Gestion des secrets d'authentification

Notion	À retenir
Dissémination secrets	Maîtriser la dissémination : diversifier/renouveler les **mots de passe administrateurs locaux**, traiter les **scripts**, prohiber les **GPP**, traiter **tâches planifiées/services** et protéger les **partages réseau**.
IGC et comptes	Traiter les risques **IGC** sur le **Tier zéro**, proscrire les **certificats faibles**, traiter les **secrets API** et **accès physiques**, renouveler régulièrement `krbtgt` et contrôler les **comptes de trust/ordinateur sensibles**.

Infrastructures support du Tier zéro

Notion	À retenir
Sauvegarde, stockage, virtualisation	Catégorisation en Tiers traitée **spécifiquement** ; agents de gestion centralisée **limités** sur le Tier zéro ; solutions de protection contre les menaces traitées à part.
WSUS et réseau	Architecture **WSUS** préservant le cloisonnement ; protocoles du Tier zéro sécurisés ; flux **filtrés** vers les réseaux non maîtrisés et le reste du SI.
Sécurité physique	Attention particulière ; à défaut, **RODC** sécurisés ; **UO dédiée** aux objets du Tier zéro avec stratégies restreintes.

Secrets réutilisables : NTLM et Kerberos

Cible / Contexte	Mesure de sécurité
Windows Defender Credential Guard	Uniquement en **défense en profondeur**.
Remote Credential Guard	Jamais entre **zones de confiance hétérogènes**.
Connexion à des ressources de **moindre confiance**	**Encadrée** et **restreinte**.
Kerberos	Délégations traitées ; **préauthentification** préservée pour les comptes du Tier zéro ; **blindage Kerberos** activé ; pas de secret du Tier zéro exposé par **SPN**.
NTLM	**Interdit** pour les comptes du Tier zéro ; durci ailleurs ; trafic sortant **bloqué** depuis le Tier zéro puis tout le SI si possible ; LDAP, SMB et Web protégés contre le **relais NTLM**.

Administration à distance et postes d'administration

Notion	À retenir
Clients de connexion distante	Usage **encadré et restreint** ; clients autorisés **durcis**.
Postes d'administration	Tier zéro administré depuis des postes **physiquement dédiés** ; mutualisation encadrée voire proscrite ; postes multiniveaux catégorisés dans le Tier adéquat.
Depuis le Tier zéro	Accès aux zones de moindre confiance **restreint**, comme les comptes autorisés au déport d'affichage.
Ressources intermédiaires	Respecter les règles de positionnement ; **forêt d'administration dédiée** évitée sauf nécessité, alors **cloisonnée**.

Pièges et confusions

- ⚠ Compter uniquement sur le cloisonnement réseau pour sécuriser un système AD.
- ⚠ Croire que les pare-feux peuvent contrôler le contenu légitime ou malveillant des communications RPC, SMB et Kerberos.
- ⚠ Utiliser Windows Defender Remote Credential Guard entre des zones de confiance hétérogènes.
- ⚠ Penser qu'une attaque cible uniquement le Tier zéro alors qu'elle peut viser l'exfiltration de valeurs métiers via des API.

Sigles et définitions

Tier zéro	cœur de confiance de l'organisation
Chemin de contrôle	succession de relations de permissions ou de dépendances techniques permettant de progresser vers une ressource de plus haute confiance
Enterprise access model	évolution du modèle en trois Tiers publiée par Microsoft fin 2020
NTLM	protocole d'authentification dont les secrets sont réutilisables directement par un attaquant
Kerberos	protocole d'authentification dont les clés sont réutilisables directement par un attaquant
RODC	contrôleur de domaine en lecture seule

Auto-test

1. Quels sont les deux protocoles d'authentification de l'environnement Windows ?
2. Que signifie l'acronyme RODC ?
3. Quel niveau du modèle en trois Tiers représente les moyens d'accès utilisateur ?
4. Quelle est la conséquence de l'utilisation de Remote Credential Guard entre zones de confiance hétérogènes ?
5. Quel niveau du modèle en trois Tiers correspond aux valeurs métiers ?

Réponses : **1.** NTLM et Kerberos · **2.** contrôleur de domaine en lecture seule · **3.** Tier deux · **4.** Exposer les secrets réutilisables d'un Tier de haute confiance à une machine de moindre confiance · **5.** Tier un

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.